

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-29 09:00 WIB

Top 5 Highlights

- Nvidia releases Open Agent Safety Platform to monitor and govern agentic AI
- Apple Emergency Patch for iOS 26, macOS26, macOS15 (CVE-2026-86950), (Mon, Sep 28th)
- QR code vulnerability allows attackers to hijack branded domains
- Nvidia launches open-source platform to enhance AI agent safety
- Malicious ad-blocking extensions exploit Chrome Web Store trust

Threat Intelligence (10)

01. Lunex malware platform uses Psychedelic Stealer via compromised Ukrainian sites

The attack chain begins with a fake CAPTCHA page, leading to the deployment of a fully-featured command-and-control (C2) agent.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/lunex-malware-platform-uses-psychedelic-stealer-via-compromised-ukrainian-sites>

02. RatHat Android Malware Console Uses Gemini to Identify Higher-Value Victims

RatHat's operators build and publish the Android banking trojan and control infected phones from a web console, according to security company Cleafy. Cleafy has traced nearly 100 deployments of that console since April 2026. It said this fits a malware-as-a-service model, in which each customer runs a separate copy. The console stores what the malware colle...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/rathat-android-malware-console-uses.html>

03. NeedyMantis: Unpacking a post-compromise malware family used in targeted operations

Microsoft Threat Intelligence identified NeedyMantis, a modular post-compromise malware framework used in targeted intrusions that combines custom loaders, encrypted archives, and extensible components to maintain long-term access and support follow-on operations. The post NeedyMantis: Unpacking a post-compromise malware family used in targeted operations a...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/09/28/needymantis-unpacking-a-post-compromise-malware-family-used-in-targeted-operations/>

04. Ex-soldier's telecom hacking spree earns him 70 months

Active-duty campaign targeted at least ten organizations and sought \$1 million in ransom payments

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/cyber-crime/2026/09/28/ex-soldiers-telecom-hacking-spree-earns-him-70-months/5299440>

05. Carbonato Botnet Compromises Docker Hosts to Deploy Telegram-Controlled Hermes AI Agent

Cybersecurity researchers have disclosed details of a new botnet malware called Carbonato that's targeting exposed Docker daemons to deploy an open-source artificial intelligence (AI) agent framework called Hermes Agent. "The implant installs the framework unchanged, then overwrites its SOUL.md persona file," ThreatDown said. "The 39-line prompt directs it..."

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/carbonato-botnet-compromises-docker.html>

06. [+24h Old] Stolen AI credentials feed growing LLM proxy economy

Cyber threat groups have increasingly targeted enterprise AI assets, such as credentials, cloud environments, and research, as a means for operationalizing their own use of AI...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.csoonline.com/article/4227199/stolen-ai-credentials-feed-growing-llm-proxy-economy.html>

07. [+24h Old] ISC Stormcast For Monday, September 28th, 2026

<https://isc.sans.edu/podcastdetail/10112>, (Mon, Sep 28th)

ISC Stormcast For Monday, September 28th, 2026

<https://isc.sans.edu/podcastdetail/10112>, (Mon, Sep 28th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33374>

08. [+24h Old] Quarantined isn't contained: Agentic phishing response with Elastic and Sublime

The native Sublime Security integration sends email detections into Elastic Security, where phishing incident response can tie a quarantined email to what happens next on

the endpoint and pull the threat from every mailbox it reached.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.elastic.co/security-labs/blog/phishing-incident-response-sublime-security>

09. [+48h Old] Lunex Stealer Abuses AMD Driver to Disable Security Monitoring and Steal Browser Credentials

The Psychedelic Stealer malware distributed via compromised Ukrainian websites using ClickFix-style Cloudflare verification checks is part of a wider malware-as-a-service (MaaS) platform called Lunex. The new findings come from Ontinue, which described the activity as a four-stage attack chain aimed at targeting Ukrainian-speaking users. "The attack chain b...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/lunex-stealer-abuses-amd-driver-to.html>

10. [+48h Old] GitHub Actions re-enabled with Mini Shai-Hulud payload still active

Two third-party GitHub Actions previously compromised in a Mini Shai-Hulud campaign were re-enabled by their maintainer and remained accessible for more than a week despite still pointing to malicious code. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/github-actions-re-enabled-with-mini-shai-hulud-payload-still-active/>

Latest Vulnerabilities (10)

01. Nvidia releases Open Agent Safety Platform to monitor and govern agentic AI

Nvidia on Monday rolled out an agentic governance system called the Open Agent Safety Platform that combines software with out-of-band DPU-based silicon in a reference system design that it says will secure agents "from testing to deployment." But while the Nvidia design's silicon-based component provides some cybersecurity advantages, analysts argued that...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4227843/nvidia-releases-open-agent-safety-platform-to-monitor-and-govern-agentic-ai.html>

02. Apple Emergency Patch for iOS 26, macOS26, macOS15 (CVE-2026-86950), (Mon, Sep 28th)

Apple today released patches for all of its operating systems. However, only patches for older branches include a security fix. The vulnerability being addressed in iOS 26, macOS 26 and macOS 15 is already being exploited. iOS and macOS 27 are not affected. Today's update for the current "27" branch does not address security issues, but fixes som...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://isc.sans.edu/diary/rss/33376>

03. QR code vulnerability allows attackers to hijack branded domains

Security researcher Farzan Karimi discovered that QR Tiger's "Own Short Domain" feature does not adequately verify domain ownership when a custom domain is added.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/qr-code-vulnerability-allows-attackers-to-hijack-branded-domains>

04. Nvidia launches open-source platform to enhance AI agent safety

This initiative addresses growing concerns over AI agents operating autonomously and potentially causing security incidents.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/nvidia-launches-open-source-platform-to-enhance-ai-agent-safety>

05. Malicious ad-blocking extensions exploit Chrome Web Store trust

Researchers at Bay Area Labs have identified "Poper Blocker," an ad-blocking extension with a "Featured" badge and "Established Publisher" status from Google, as malware.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/malicious-ad-blocking-extensions-exploit-chrome-web-store-trust>

06. Exploit.in data reveals enduring roots of cybercrime in early 2000s forum

The analysis of the Exploit.in database, containing nearly 10,000 members and over 80,000 posts, highlights a surprising continuity of users and practices that have persisted for two decades.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/exploit-in-data-reveals-enduring-roots-of-cybercrime-in-early-2000s-forum>

07. Clop ransomware gang moves to new server after Grav CMS vulnerability exploited

ShinyHunters claimed to have stolen source code, server logs, and private keys from the Clop server, subsequently demanding a ransom.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/clop-ransomware-gang-moves-to-new-server-after-grav-cms-vulnerability-exploited>

08. One Packet Can Crash OT Servers in Industrial Sectors

A high-severity zero-day vulnerability affects the TDengine time-series database used across industrial, IoT, energy, and automotive environments.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/ics-ot-security/one-packet-crash-servers-tdengine>

09. JadePuffer crims hijacked Azure identities and used them to blow up cloud resources

Smells like more agentic ransomware, Redmond warns

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/09/28/jadepuffer-crim-hijacked-azure-identities-and-used-them-to-blow-up-cloud-resources/5299591>

10. Carbonato Botnet Puts an AI Agent on Hacked Docker Hosts

The botnet uses the open source Hermes Agent AI framework to execute commands via Telegram and steal AI API keys from exposed Docker hosts.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/identity-access-management-security/carbonato-botnet-ai-agent-hacked-docker-hosts>

Data Breach & Cybercrime (10)

01. Google ads deliver sophisticated tech support scam targeting Windows and Mac users

The malicious Google ads appeared across various high-traffic websites, including those for maps, weather, and real estate.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/google-ads-deliver-sophisticated-tech-support-scam-targeting-windows-and-mac-users>

02. Japan's Keio confirms ransomware attack disrupted business systems

Keio Corporation (Keio), a major private railway operator in Japan, said its network was hit by a ransomware attack over the weekend, disrupting some of its business systems. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/japans-keio-confirms-ransomware-attack-disrupted-business-systems/>

03. Times Car confirms data breach affecting 6.6 million user accounts

Japanese car-sharing service Times Car has confirmed that approximately 6.6 million user accounts were compromised in a cyberattack disclosed late last week. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/times-car-confirms-data-breach-affecting-66-million-user-accounts/>

04. Dutch police confirm arrest in ShinyHunters hacking investigation

Dutch police have confirmed that a 24-year-old Amsterdam man arrested earlier this month was detained as part of an investigation into the ShinyHunters hacking group. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/dutch-police-confirm-arrest-in-shinyhunters-hacking-investigation/>

05. Hackers Use NeedyMantis to Maintain Long-Term Access in Breached Networks

Hackers have used a malware family called NeedyMantis to maintain long-term access to networks they had already breached, Microsoft said in a technical analysis. The malware has been seen in a small number of targeted intrusions at telecommunications organizations, universities, medical nonprofits, intergovernmental organizations, and government contractors...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/09/hackers-use-needymantis-to-maintain.html>

06. Dutch Police Arrest 'Reformed' Hacker in Shiny Hunters Investigation

Authorities in the Netherlands have arrested a 23-year-old convicted cybercriminal on suspicion of aiding in data thefts and extortions by the prolific hacker group ShinyHunters. In the days immediately following the suspect's arrest, remaining ShinyHunters members dramatically escalated their attacks, stealing highly sensitive data from the FBI and extorti...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://krebsonsecurity.com/2026/09/dutch-police-arrest-reformed-hacker-in-shiny-hunters-investigation/>

07. Bitget Restarts Bitcoin Withdrawals Following \$387.5m Wallet Breach

Bitget has restarted Bitcoin withdrawals after a \$387.5m breach of its hot and warm wallets

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/bitget-restarts-withdrawals-387-5m/>

08. Autonomous agents attack Azure using compromised identities, destroying resources

Jadepuffer, an autonomous AI attacker first identified in July, has expanded into Azure environments, using compromised digital identities to enumerate resources, delete cloud assets and collect other credentials, according to Microsoft. The activity includes “extensive Azure-focused resource destruction activity using compromised service principals and clo...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.csoonline.com/article/4227657/autonomous-agents-attack-azure-using-compromised-identities-and-destroying-resources.html>

09. 80,000+ Organizations Had AI Logins Stolen: From Shadow AI to LLMjacking

Infostealer logs exposed AI account credentials and sessions tied to more than 80,000 corporate domains, creating risks ranging from stolen conversations to LLMjacking. SOCRadar examines the growing market for stolen AI logins and how organizations can identify their exposure. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/80-000-plus-organizations-had-ai-logins-stolen-from-shadow-ai-to-llmjacking/>

10. FBI job portals remain offline after ShinyHunters claims breach via PeopleSoft zero-day

The FBI's online portals for job applicants (at apply.fbijobs.gov) and special agent applicants (at fbijobs.gov/special-agents) are still unavailable, following what appears to be successful compromises by the ShinyHunters cyber extortion group. Last week, the United States' domestic intelligence and security service confirmed it was investigating ShinyHunt...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/28/fbi-job-portals-offline-shinyhunters-breach/>